

TP3, eleve : Injection SQL et XSS (OWASP A03)

- Jour 2 - Duree : ~1h15 - Dossier : `jour2-ctf/` (port 8002)
- Cible : La Boutique du Capitaine

Contexte

L'injection, c'est quand une donnee que vous fournissez est interpretee comme du code : par la base de donnees (SQLi) ou par le navigateur d'une victime (XSS). Une seule cause racine, plusieurs visages.

Mise en place

```
cd jour2-ctf && docker compose up -d --build # cible :8002, scoreboard :8002/scoreboard
```

Challenges

06 - La serrure en sucre (SQLi, contournement d'auth)

Objectif : vous connecter sans connaitre le mot de passe d'un compte. - Indice 1 : le formulaire de login construit peut-etre sa requete SQL en collant vos saisies. - Indice 2 : que se passe-t-il si votre saisie contient une apostrophe ? - Indice 3 : en SQL, `--` commente la fin d'une ligne.

13 - La carte derriere la carte (SQLi UNION)

Objectif : faire cracher a la recherche d'equipage des donnees qu'elle ne devrait pas montrer. - Indice 1 : la recherche renvoie des colonnes. Combien ? - Indice 2 : `UNION SELECT` permet d'ajouter vos propres lignes au resultat. - Indice 3 : il existe une table qui contient autre chose que des utilisateurs.

05 - Le perroquet bavard (XSS reflechie)

Objectif : faire executer votre propre JavaScript sur la page d'accueil matelot. - Indice 1 : la page vous repete via le parametre `?name=`. - Indice 2 : votre saisie est-elle echappee avant affichage ? - Indice 3 : une balise `<script>` ou un attribut `onerror` d'image peuvent declencher du code.

20 - Le message grave (XSS stockee + bot admin)

Objectif : le capitaine relit son livre d'or ; faites-lui livrer son propre cookie. - Indice 1 : votre message est-il affiche tel quel aux autres visiteurs ? - Indice 2 : un script injecte peut envoyer `document.cookie` vers une URL que vous controlez. - Indice 3 : la stack fournit un collecteur et un moyen de declencher la visite du capitaine. Observez les routes disponibles.

Outils

Burp Suite (onglet Repeater pour rejouer/muter), DevTools, `curl`.

Validation

Soumettez chaque flag sur <http://localhost:8002/scoreboard>.

Livrable attendu

Pour chaque challenge : le payload utilise, la cause racine (en une phrase), et l'idée de correction. Vous reutiliserez ces notes au TP6.